Pengembangan Dynamic Cyber Risk Scoring Engine Berbasis Telemetri Wazuh

Studi Kasus Simulasi Perbankan Daerah

CAPSTONE PROJECT KOLABORASI INDUSTRI – ITS

2026

Latar Belakang

Security Operations Center (SOC) modern menghasilkan ribuan alert dan log setiap harinya. Namun, volume data yang besar ini justru menciptakan tantangan baru: bagaimana menerjemahkan sinyal teknis menjadi informasi risiko yang bermakna bagi pengambil keputusan?

Tantangan SOC

- Volume alert sangat tinggi, sulit diprioritaskan secara manual
- Bahasa teknis sulit dipahami manajemen non-teknis
- Tidak ada scoring risiko terpadu per aset

Kebutuhan Manajemen

- Prioritas mitigasi berbasis risiko nyata
- Pemantauan tren risiko secara periodik
- Ringkasan eksekutif untuk keputusan cepat dan tepat

Problem Statement

Inti permasalahan yang ingin diselesaikan proyek ini adalah: **bagaimana mengubah telemetri Wazuh — berupa alert, log, dan data kerentanan — menjadi informasi risiko yang dapat digunakan secara langsung?**

1

Skor Risiko Dinamis

Setiap aset (server, workstation, aplikasi) mendapatkan skor risiko yang diperbarui secara periodik berdasarkan telemetri terkini.

2

Ringkasan Eksekutif

Menyajikan indeks risiko global dan area risiko tertinggi dalam format yang mudah dipahami oleh CISO dan manajemen.

3

Insight yang Actionable

Menghasilkan daftar prioritas mitigasi yang jelas — bukan sekadar angka, melainkan rekomendasi langkah konkret berikutnya.

Tujuan Proyek

Proyek ini bertujuan membangun **Proof of Concept (PoC)** Risk Scoring Engine berbasis telemetri Wazuh dalam lingkungan simulasi perbankan daerah. Output utama yang diharapkan mencakup empat komponen berikut:

🔬 PoC Engine

Membangun Risk Scoring Engine berbasis data simulasi Wazuh yang dapat berjalan end-to-end.

📊 Skor Dinamis

Menghasilkan skor risiko per aset (server/workstation/app) yang diperbarui secara berkala.

🖥️ Dashboard Risiko

Menyediakan tampilan ranking aset, tren risiko, dan ringkasan untuk pengambil keputusan.

⚙️ Model Transparan

Scoring berbasis rule-based yang explainable — setiap skor dapat dijelaskan faktor penyebabnya.

Scope: In-Scope

Berikut adalah komponen yang secara eksplisit masuk dalam lingkup pengerjaan proyek ini, mencakup tiga lapisan utama: ingesti data, mesin scoring, dan visualisasi.

Ingesti Telemetri

- Wazuh alert (severity, rule, agent)
- Vulnerability summary (CVSS agregat)
- Asset inventory + criticality (dummy CMDB)

Risk Scoring Engine

- Weighted scoring + normalisasi
- Breakdown faktor risiko per komponen
- Trend dan time-series analysis

Dashboard & Simulasi

- Top risk assets ranking
- Risk trend visualization
- Drill-down penyebab skor
- Simulasi spike event & remediation decay

Out of Scope — Batas Proyek

Mendefinisikan batas proyek dengan tegas sama pentingnya dengan mendefinisikan tujuannya. Berikut adalah hal-hal yang **tidak termasuk** dalam lingkup proyek ini, untuk menjaga fokus dan menghindari scope creep.

❌ Akses Sistem Produksi

Tidak ada akses ke sistem atau infrastruktur produksi bank manapun. Seluruh pengujian dilakukan di lingkungan lab ITS yang terisolasi.

❌ Data Log Asli

Tidak menggunakan log atau data produksi nyata. Seluruh dataset bersifat simulasi (dummy/replay) untuk keperluan PoC.

❌ Integrasi Enterprise

Tidak mencakup integrasi dengan core banking, Active Directory, maupun SIEM enterprise yang ada.

❌ AI/ML & SOAR

Tidak berfokus pada model machine learning kompleks atau otomasi respons insiden (SOAR automation) pada tahap ini.

Use Case Utama

Sistem dirancang untuk mendukung enam skenario penggunaan kritis yang menjawab kebutuhan nyata tim keamanan dan manajemen perbankan daerah.

Risk Score per Asset

Skor 0–100 atau level L/M/H untuk setiap aset terdaftar.

Risk Breakdown

Dekomposisi skor ke faktor: ancaman, kerentanan, dan kritikalitas aset.

Risk Trend

Pemantauan tren risiko harian dan mingguan untuk deteksi dini perubahan postur keamanan.

Risk Spike Detection

Deteksi kenaikan skor risiko signifikan sebagai indikator awal insiden.

Executive View

Indeks risiko global dan ringkasan area risiko tertinggi untuk lapisan manajemen.

Prioritization List

Rekomendasi urutan mitigasi berdasarkan skor risiko tertinggi dan dampak potensial.

User Story — Perspektif CISO

Berikut contoh user story yang menjadi dasar perancangan fitur sistem, ditulis dari perspektif Chief Information Security Officer (CISO) sebagai pengguna utama executive view.

User Story

> Sebagai **CISO**, saya ingin melihat **skor risiko per aset secara real-time**, agar saya dapat menentukan prioritas mitigasi dengan cepat dan berbasis data — tanpa harus membaca ratusan alert teknis secara manual.

Acceptance Criteria

- Tampil daftar **Top 5–10 risk assets** dengan skor terkini
- Skor diperbarui secara **periodik** (per jam atau per hari)
- Klik pada aset → tampil **breakdown penyebab skor** (threat, vuln, criticality)
- Tersedia tampilan **tren risiko** dalam periode tertentu

Product Backlog — Epic Overview

Seluruh pekerjaan proyek diorganisasikan ke dalam lima epic yang mencakup perjalanan lengkap dari fondasi data hingga dokumentasi akhir.

Epic A

Data Ingestion & Asset Foundation

Epic B

Risk Scoring Engine

Epic C

Visualization & Executive Dashboard

Epic D

Simulation & Demo Capability

Epic E

Deployment & Documentation

MVP Definition — Kriteria Keberhasilan PoC

PoC dinyatakan **berhasil** apabila keempat kondisi berikut terpenuhi secara end-to-end pada sprint akhir:

✅ Data Masuk

Alert Wazuh berhasil diingesti — baik via replay dataset maupun Wazuh lab instance yang aktif.

✅ Skor Dihitung

Risk scoring engine menghasilkan skor per aset secara otomatis berdasarkan data yang masuk.

✅ Dashboard Aktif

Dashboard menampilkan ranking aset, tren risiko, dan drill-down penyebab skor dengan jelas.

✅ Simulasi Terlihat

Simulasi spike meningkatkan skor secara visible di dashboard, dan skor turun setelah remediation.

Simulasi Input Wazuh — Pendekatan Dataset

Karena tidak menggunakan data produksi, proyek mengandalkan pendekatan simulasi berlapis. Dataset dirancang untuk mencakup empat skenario kritis yang merepresentasikan kondisi nyata di SOC perbankan.

Tahapan Pendekatan

1 Tahap Awal (Cepat)

Dataset replay dalam format JSON/CSV yang menyerupai struktur Wazuh alert — memungkinkan pengembangan paralel tanpa infrastruktur.

2 Tahap Lanjutan (Opsional)

Wazuh lab instance aktif dengan dummy agents untuk menghasilkan telemetri yang lebih realistis dan dinamis.

Skenario Dataset Wajib

- **Normal:** Aktivitas harian tanpa anomali signifikan
- **Spike / Incident Burst:** Lonjakan alert simulasi insiden
- **Vulnerability Cluster:** Konsentrasi CVE pada aset tertentu
- **Remediation + Decay:** Skor menurun setelah perbaikan

Data Contract — Struktur Field Minimal

Data contract mendefinisikan format minimum yang wajib dipenuhi oleh setiap event input maupun output scoring. Ini adalah fondasi interoperabilitas seluruh komponen sistem.

📥 Input Event (Telemetri Wazuh)

Field	Deskripsi
timestamp	Waktu kejadian event
asset_id / hostname	Identifikasi unik aset
severity	Level dari Wazuh rule (1–15)
category	auth / malware / integrity / network
event_type	alert / vuln / control

📤 Output Scoring (Risk Engine)

Field	Deskripsi
asset_id	Identifikasi aset yang dinilai
risk_score	Skor risiko agregat (0–100)
risk_components	Breakdown: threat / vuln / criticality
timestamp	Waktu perhitungan skor

Data contract harus dikunci di Sprint 1 sebelum pengembangan engine dan dashboard dimulai, untuk memastikan konsistensi antar komponen tim.

Environment Lab — Disediakan ITS

Seluruh pengembangan dilakukan dalam lingkungan lab ITS yang terisolasi. Prinsip utama: **full lab, data dummy, zero production access.** Stack berikut menjadi standar deployment proyek ini.

Version Control

Git repo + issue tracker untuk manajemen kode dan backlog tim.

Shared VM

1 VM Ubuntu bersama untuk sprint review dan demo akhir.

Docker Compose

Seluruh layanan dikemas dalam container untuk konsistensi environment.

Database

PostgreSQL atau Elasticsearch sebagai penyimpanan time-series data scoring.

Risk Engine

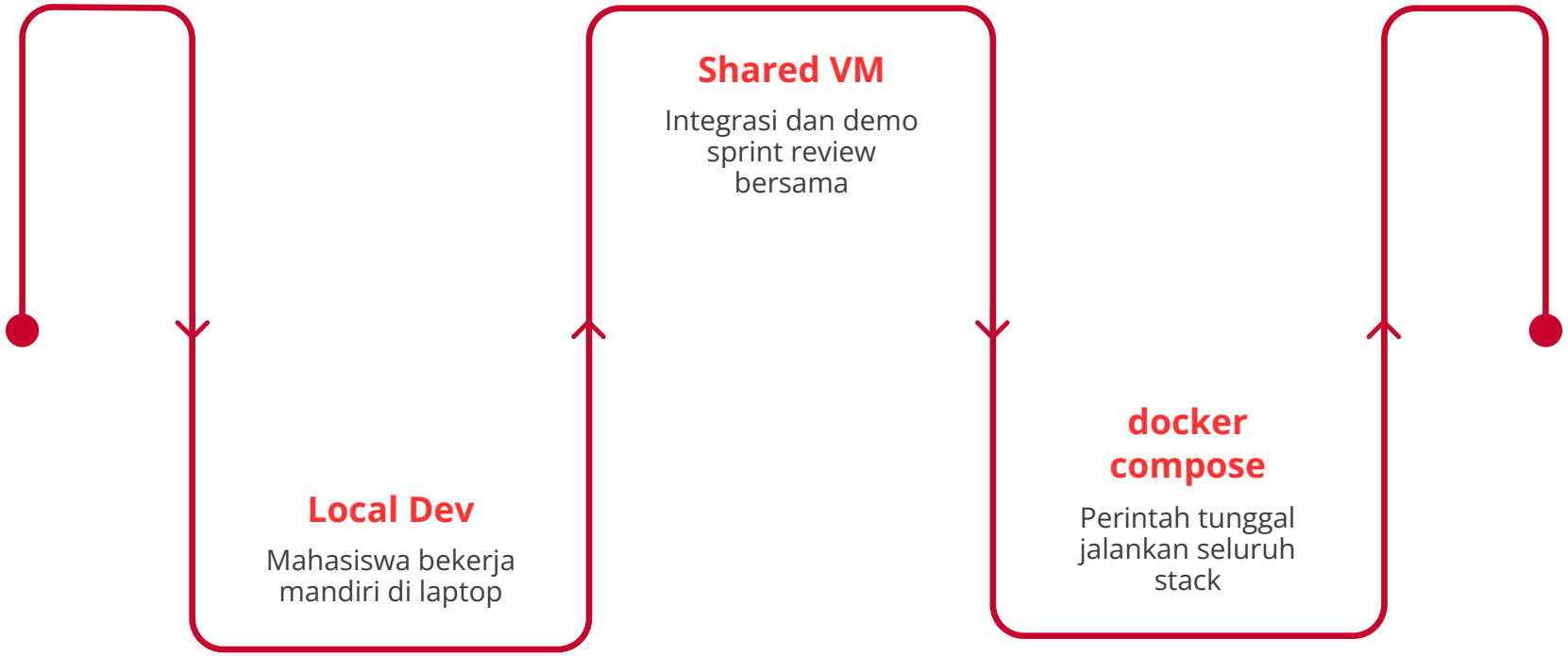
Python service sebagai inti kalkulasi weighted scoring dan normalisasi.

Dashboard

Streamlit, Grafana, atau Metabase untuk tampilan eksekutif dan operasional.

Deployment Model — Standar Operasional

Model deployment dirancang agar setiap anggota tim dapat bekerja secara mandiri di lokal, sementara shared VM berfungsi sebagai staging untuk demo sprint review bersama stakeholder industri.



🔁 Repeatable

Setiap anggota tim dapat mereproduksi environment yang identik.

✔️ Konsisten

Tidak ada "works on my machine" — satu perintah untuk semua.

🎬 Demo Ready

Demo end-to-end dapat dijalankan kapan saja tanpa konfigurasi tambahan.

Scrum Plan — 12 Minggu / 6 Sprint

Proyek dijalankan menggunakan kerangka Scrum dengan enam sprint dua mingguan. Setiap sprint memiliki deliverable yang terukur dan terhubung langsung ke Epic di backlog.

1

Sprint 1–2

Foundation

Data contract, ingestion pipeline, asset inventory, docker compose setup

2

Sprint 3–4

Core Engine

Risk score per asset, breakdown komponen, penyimpanan time-series DB

3

Sprint 5

Visualization

Dashboard ranking + tren + drill-down penyebab skor

4

Sprint 6

Final Demo

Simulasi incident/remediation, dokumentasi lengkap, presentasi akhir

Mekanisme Rapat & Kolaborasi

Struktur komunikasi yang konsisten adalah kunci keberhasilan proyek kolaborasi industri-akademik. Tiga mekanisme rapat berikut memastikan progres terpantau dan isu teknis ditangani tepat waktu.

Weekly Sync

Durasi: 30–45 menit
Agenda: review progress, identifikasi blocker, perencanaan minggu berikutnya. Wajib dihadiri seluruh anggota tim.

Sprint Review

Checkpoint Industri
Demo deliverable sprint + review relevansi use case bersama mitra industri. Menghasilkan feedback langsung untuk sprint berikutnya.

Technical Deep Dive

Ad-hoc / sesuai kebutuhan
Dijadwalkan khusus saat ada isu integrasi atau keputusan arsitektur yang memerlukan diskusi mendalam.

Definition of Done (DoD)

Sebuah sprint dinyatakan **"Done"** bukan hanya saat kode berjalan, tetapi ketika seluruh kriteria berikut terpenuhi. DoD ini memastikan kualitas deliverable konsisten di setiap iterasi.

→ Komponen Berjalan Sesuai Target

Semua fitur yang direncanakan dalam sprint berhasil diimplementasikan dan diuji tanpa error kritis.

→ Demo End-to-End Tersedia

Tim mampu mendemonstrasikan alur kerja lengkap — dari input data hingga output tampilan — kepada reviewer industri.

→ Dokumentasi Ringkas Dibuat

Minimal berupa diagram arsitektur, slide ringkasan, atau README yang menjelaskan komponen yang dibangun.

→ Value untuk Risk Management Dapat Dijelaskan

Tim mampu mengartikulasikan manfaat bisnis dari deliverable sprint — bukan sekadar menjelaskan implementasi teknis.

Risiko Utama & Strategi Mitigasi

Tiga risiko berikut diidentifikasi sebagai ancaman terbesar terhadap keberhasilan proyek. Setiap risiko disertai strategi mitigasi konkret yang diterapkan sejak awal pengerjaan.

⚠️ Dataset Tidak Realistis

Risiko: Simulasi terlalu sederhana → scoring tidak meaningful → sulit divalidasi relevansinya.
Mitigasi: Kunci data contract dari Sprint 1 dengan skenario lengkap (normal, spike, vuln, remediation).

⚠️ Over-Engineering

Risiko: Kompleksitas teknis berlebihan (ML/AI prematur) → timeline meleset → MVP tidak tercapai.
Mitigasi: Gunakan rule-based scoring yang explainable. Simpan kompleksitas sebagai backlog fase berikutnya.

⚠️ Dashboard Terlalu Teknis

Risiko: Output tidak dapat digunakan oleh manajemen non-teknis → kehilangan nilai bisnis.
Mitigasi: Review industri per sprint untuk memastikan tampilan dan bahasa sesuai kebutuhan eksekutif.

Timeline Ringkas — 12 Minggu

Proyek dibagi menjadi empat fase besar yang saling berkesinambungan. Setiap fase menghasilkan deliverable yang menjadi fondasi fase berikutnya.

Fase 1 (Minggu 1-3): Desain & Model. Kontrak Data, Arsitektur, Scoring Model.

Fase 2 (Minggu 4-7): Bangun Engine. Pipeline Ingest, Scoring Risk, Database.

Fase 3 (Minggu 8-10): Dasbor & Simulasi. Eksekutif, Spike & Remidiasi.

Fase 4 (Minggu11-12): Finalisasi. Demo, Laporan Akhir, Dokumentasi.

Closing — Target & Output Proyek

Proyek ini membuktikan satu proposisi inti: **telemetri SOC dapat diubah menjadi indikator risiko dinamis yang bermakna bagi manajemen** — bukan sekadar deretan alert teknis yang membebani analis.

🎯 Target Utama

Membuktikan bahwa telemetri Wazuh dapat menjadi sumber scoring risiko dinamis yang relevan untuk konteks perbankan daerah.

📦 Output Deliverable

PoC end-to-end yang berjalan, dashboard risiko eksekutif, dan dokumentasi model scoring yang transparan.

➡️ Next Step

Diskusi bersama mitra industri mengenai roadmap pengembangan lanjutan — dari PoC menuju implementasi nyata di lingkungan produksi.

Pertanyaan untuk Diskusi: Apa prioritas fitur yang paling relevan untuk konteks operasional Bank Daerah Anda? Apakah ada use case tambahan yang perlu diakomodasi dalam roadmap berikutnya?

Terima Kasih

Capstone Project Kolaborasi Industri — Institut Teknologi Sepuluh Nopember (ITS)
2026

📧 Kontak Tim

Hubungi supervisor proyek atau koordinator capstone ITS untuk informasi lebih lanjut.

📁 Repository

Seluruh kode, dokumentasi, dan dataset simulasi tersedia di Git repository proyek.

🔗 Demo

Demo live dashboard tersedia atas permintaan — jalankan via `docker compose up` di shared VM ITS.